

ABC Cloud Technologies Ltd.

ISO/IEC 27001:2022 Internal Audit Report

Audit ID: IA-2026-001 | Version 1.0 | August 2026

Audit Type	Internal ISMS Audit
Audit Period	24–28 August 2026
Audit Scope	ISMS governance, risk management, access, cloud, vulnerability management, backup, monitoring, incident man
Audit Criteria	ISO/IEC 27001:2022; approved ISMS documentation; Statement of Applicability; Risk Treatment Plan; applicabl
Lead Auditor	GRC / Compliance Lead
Report Status	Portfolio Simulation

1. Executive Summary

The internal audit was designed to evaluate whether the simulated Information Security Management System (ISMS) is established, implemented and maintained against defined audit criteria, with particular attention to risk treatment and selected Annex A controls.

The audit programme used a risk-based approach. Higher attention was assigned to access and privileged access, cloud configuration, vulnerabilities, backup and recovery, logging and monitoring, secure development, production change management, incident management and corrective actions.

Overall conclusion: the ISMS framework is established at a portfolio level, but several controls require further implementation, evidence maturity or effectiveness verification before they could reasonably be considered fully effective.

2. Audit Objectives

- Evaluate whether ISMS processes are established and maintained against defined criteria.
- Assess whether information-security risks are identified, evaluated and treated consistently.
- Assess implementation of selected Annex A controls based on the Statement of Applicability.
- Evaluate operating effectiveness of high-priority controls using objective evidence and sampling.
- Determine whether corrective actions are managed and subject to effectiveness verification.
- Identify opportunities to improve the ISMS and reduce material information-security risk.

3. Audit Methodology

The audit methodology consisted of document review, interviews, process walkthroughs, evidence sampling, control testing and evaluation of objective evidence. Sampling was risk-based and focused on privileged access, recent joiner/mover/leaver events, critical vulnerabilities, backups, production changes, security alerts, repositories, training records and corrective actions.

4. Areas Audited

Area	Primary Criteria / Controls
ISMS governance & risk	Clauses 4–10; Risk Register; Risk Treatment Plan
Statement of Applicability	Clause 6.1.3; selected Annex A controls
Access & identity	A.5.15, A.5.16, A.5.17, A.8.2
Cloud & configuration	A.5.23, A.8.9
Vulnerability & endpoint security	A.8.7, A.8.8
Backup & continuity	A.8.13, A.5.30
Logging, monitoring & incidents	A.8.15, A.8.16, A.5.24, A.5.26
Secure development & changes	A.8.4, A.8.28, A.8.31, A.8.32
People & remote working	A.6.3, A.6.7
Corrective action & improvement	Clauses 9–10

5. Audit Results Summary

Result Category	Portfolio Result	Management Interpretation
Conforming / implemented	Several areas	Core processes and selected controls have defined implementation evidence or are
Observation / improvement	Multiple areas	Evidence maturity, periodic review and consistency should be improved.
Minor nonconformity	3	Limited control gaps requiring corrective action and verification.
Major nonconformity	1	Significant control weakness requiring management priority and systemic corrective

6. Key Findings

Finding ID	Classification	Area	Finding Summary	Priority
F-001	Major Nonconformity	Privileged Access / MFA	Privileged-access governance and authentication evidence is not consistently sufficient.	High
F-002	Minor Nonconformity	Backup & Recovery	Backup evidence exists, but restoration testing and documented recovery verification are missing.	Medium
F-003	Minor Nonconformity	Logging & Monitoring	Logging and monitoring requirements are established, but evidence of periodic review is missing.	Medium
F-004	Minor Nonconformity	Secure Development	Secure coding and security-testing evidence is not consistently maintained across sample releases.	Medium

7. Detailed Finding — F-001

Classification: Major Nonconformity

Criterion: Applicable access-control and authentication requirements, including A.5.15, A.5.17 and A.8.2, as reflected in the approved SoA and risk treatment process.

Condition: The available evidence does not consistently demonstrate that privileged accounts are subject to complete authorization, MFA coverage, periodic review and documented remediation of exceptions.

Risk: Excessive or compromised privileged access could enable unauthorized changes, data exposure or compromise of critical systems.

Recommended action: Establish a complete privileged-account inventory, enforce applicable MFA, formalize approval and quarterly recertification, document exceptions, and perform an effectiveness review.

8. Detailed Findings — F-002 to F-004

F-002 — Backup & Recovery: Define recovery-test coverage for all critical workloads, retain restore-test evidence and ensure failed tests generate tracked corrective actions.

F-003 — Logging & Monitoring: Formalize minimum logging requirements, alert-review responsibilities, escalation criteria and evidence retention for periodic monitoring activities.

F-004 — Secure Development: Require consistent retention of secure-code review and security-testing evidence for sampled releases, with exceptions formally documented and approved.

9. Positive Practices Identified

- The organization has established a structured risk register and risk-treatment approach.
- The Statement of Applicability provides traceability between selected controls, risks and evidence.
- Change-management controls are defined and provide a basis for production traceability.
- Vulnerability management has a defined remediation workflow.
- Corrective actions are maintained in a dedicated register for management follow-up.

10. Recommendations

Priority	Recommendation	Owner	Target
1	Close the privileged-access/MFA gap and verify effectiveness.	IT / Security	30 days
2	Complete restore testing for critical workloads and document results.	IT Manager	30 days
3	Strengthen logging/monitoring review evidence and escalation.	Security Lead	45 days
4	Standardize secure-development evidence retention.	Engineering Lead	60 days
5	Use internal-audit results as inputs to management review and continual improvement.	QC Lead	60 days

11. Audit Conclusion

Based on the simulated audit scope, criteria and evidence reviewed, the ISMS demonstrates a developing control framework with several implemented practices. However, the identified weaknesses mean that management should prioritize corrective action, particularly for privileged access and authentication, backup recoverability, monitoring evidence and secure-development assurance.

The audit team recommends that corrective actions be tracked to completion and subjected to effectiveness verification before the related findings are closed. The results should also be considered during management review and the next risk assessment cycle.

12. Management Acknowledgement

Role	Name	Signature	Date
Executive Sponsor			
GRC / Compliance Lead			
IT / Security Owner			

Portfolio disclaimer: This report is a simulated GRC/ISO 27001 portfolio deliverable. The organization, audit dates, evidence and findings are fictional and must not be represented as an actual certification or audit result.